

KasSigner Security Architecture

Trust boundaries, Secure Boot, owner authority, storage, and assurance

1. Trust boundary

KasSigner is an offline authorization device. The online companion constructs and observes; the hardware signer holds private authority, independently parses signing requests, and requires human review. Consumer ESP32-S3 hardware is not a secure element or tamper-resistant module.

2. Key lifecycle and storage

- Always Start Fresh keeps wallet slots RAM-only and destroys them on power loss.
- Optional device-bound persistence encrypts wallet state and binds it to the ESP32-S3 HMAC eFuse capability plus the user credential.
- The mnemonic plus optional BIP39 passphrase remains the durable cross-device recovery path.
- Device-bound SD backups require the creating device. Portable steganographic backup is self-contained password-based ciphertext and therefore permits offline password guessing.

3. Boot chain and owner authority

CoreS3 production firmware separates software build verification from hardware Secure Boot v2. Pop It! is the irreversible user-controlled transition that enables the ESP32-S3 ROM trust anchor.

Digest slot	Authority
Slot 0	Official vendor RSA-3072 Secure Boot key.
Slot 1	Optional owner RSA-3072 application key, enrolled before Pop It!.
Slot 2	Closed when owner authority is enrolled.

Owner enrollment write-protects the revoke controls for slots 0 and 1. The resulting dual authority is permanent under this policy. Official applications and applications signed by the enrolled owner key can be authorized after Pop It!. Owner authority is application-only and does not authorize replacement of the vendor second-stage bootloader.

Development firmware validates/simulates owner enrollment and installation but cannot arm the production eFuse/boot-control transition.

4. Owner application installation

- OWNERKEY.KAS carries the owner public-key digest plus checksum; the RSA private key stays offline. OWNERFW.BIN is an owner-signed application image.
- The application stages OWNERFW.BIN outside the active OTA slots. The bootloader validates staged hash/length, consumes the one-shot request, copies bytes to the inactive OTA slot, then applies standard boot/anti-rollback checks and an exact owner-slot signature check.
- OTA selection changes only after all verification succeeds. A failed attempt can overwrite the inactive slot but leaves the previously selected application selected and bootable.
- A lost owner key does not block official vendor updates. A compromised enrolled owner or vendor key cannot be revoked through the configured protected policy.

5. QR and transaction authorization

- KSPT v4 multi-frame transport binds frames to a session and verifies fragment/final integrity.
- Standard PSKT/PSKB interoperability remains separate from KasSigner-specific session/network framing.
- On-device review independently distinguishes recipient output, proven wallet change, fee, network, lock/timing, multisig, covenant, and other supported context.
- Generic caller-selected wallet-key hash signing is not exposed; protocol-specific commitments use isolated keys.

6. Assurance

Control	Role
Mutation / coverage / CRAP	Test-quality and complex-path pressure.
Fuzzing	Parser/protocol robustness against malformed external input.
Architecture gates	Dependency, state-machine, inventory, and production-boundary enforcement.
Reproducible builds	Pinned build inputs and independently comparable artifacts.
Release evidence	External signed audit, clean-builder, HIL, entropy, fault, mobile, custody, and owner-authority evidence.

Repository QA is engineering evidence, not formal verification or third-party certification. Hardware/artifact release claims are gated separately by signed external evidence stored outside the source tree.

7. Residual risk

- Lab-grade physical attacks, invasive probing, glitching, and side channels unless separately demonstrated by physical/HIL evidence.
- Compromised companion/browser/node before hardware review.
- Compromised toolchains that also evade independently reproduced builds.
- Weak backup passwords, social engineering, or disclosed recovery material.
- Permanent consequences of a compromised enrolled Secure Boot authority.
- Untested hardware variants and environment-specific integration defects.